

차세대 AI 통합 보안 관제 플랫폼 (AI-SOC Platform) 상세 설계 백과사전

본 문서는 기존 Jira 기반의 수동적인 보안 관제(SOC) 티켓팅 시스템을 완벽히 대체하고, 이기종 SIEM 로그의 무손실 수집부터 AI 기반 초동 분석, 그리고 고객사 알림까지의 전 과정을 자동화하는 ****자체 구축형 통합 보안 플랫폼****의 총체적인 설계도이자 백과사전입니다.

제1장. 시스템 아키텍처 및 인프라 설계

플랫폼은 클라우드 네이티브 환경에 최적화되어 있으며, 프론트엔드의 빠른 배포와 백엔드의 고성능 비동기 처리를 위해 하이브리드 아키텍처를 채택합니다.

1.1 인프라 배포 모델 (Vercel + Supabase + Custom Backend)

개발 생산성(Vibe Coding)을 극대화하면서도 대규모 이벤트 처리의 한계를 극복하기 위해 다음과 같이 역할을 분리합니다.

- **프론트엔드 (Vercel 기반 Next.js):**
 - 관제 대시보드 UI를 배포합니다. Vercel의 CDN과 Serverless 기능을 통해 고객사 및 내부 분석가에게 지연 없는 웹 환경을 제공합니다.
- **데이터베이스 및 인증 (Supabase):**
 - **장점:** PostgreSQL 기반의 DBaaS로, 복잡한 인프라 구축 없이 인증과 API를 즉시 사용할 수 있습니다. 특히 ****RLS(Row-Level Security)****를 통해 "고객사 A는 자신의 티켓만, 분석가는 전체 티켓을 볼 수 있는" 강력한 멀티테넌시(데이터 격리)를 DB 엔진 단에서 보장합니다. **JSONB** 데이터 타입을 통해 SIEM 로그의 스키마리스(Schema-less) 저장에도 완벽히 부합합니다.
 - **단점 및 한계:** Supabase 자체만으로는 대규모 백그라운드 큐잉(Queueing)이나 Splunk API 역조회와 같은 장시간 비동기 워커 처리에 한계가 있습니다.
- **커스텀 비동기 백엔드 (FastAPI + RabbitMQ + Celery):**
 - Supabase의 단점을 보완하기 위해, SIEM 웹훅 수신과 무거운 연산(AI 분석, API 콜백)을 담당하는 별도의 워커 서버를 구축합니다.

1.2 전체 시스템 구성도 (Logical Architecture)

-- (1. Webhook) -->

| (2. Raw JSON)

| (3. Consume)

<--- (API) --->

[OpenAI / LLM] <--- (API) ---> | (4. Process, Parse, Map)

| (5. Real-time sync)

[Analyst/Client] <--- (Web) ---> [Next.js Frontend (Vercel)]

제2장. 무결성 기반 **SIEM** 로그 수집 파이프라인 (Zero-Data-Loss)

하루 500건 이상의 경보(경보 1건당 수십~수백 개의 원본 이벤트 포함 가능)가 폭주하는 상황에서 단 하나의 이벤트 누락이나 중복도 허용하지 않는 수집 메커니즘입니다.

2.1 Splunk 연동 시나리오 (콜백 / Pull 패턴)

Splunk의 기본 웹훅은 다수의 이벤트가 발생해도 검색 결과의 '첫 번째 행(First Row)'만 전송하는 치명적인 한계가 있습니다. 이를 해결하기 위해 3단계 수집 프로세스를 적용합니다.

1. 초기 웹훅 수신 (**Fire-and-Forget**): Splunk가 경보 트리거 시 메타데이터(Search ID인 `sid`와 `results_link`)만 플랫폼(FastAPI)으로 발송합니다. 서버는 이를 즉시 RabbitMQ에 적재하고 Splunk에 200 OK를 응답합니다.
2. 비동기 데이터 역조회 (**Pull**): 백그라운드의 Celery 워커가 RabbitMQ에서 `sid`를 꺼낸 뒤, Splunk REST API(`/services/search/jobs/{sid}/results`)를 호출하여 누락된 전체 원본 로그를 끌어옵니다.
3. 데이터 매핑 및 적재: 수집된 전체 로그를 JSONB 형태로 Supabase에 저장합니다.

2.2 리스크 방어 로직 (유실 및 중복 방지)

- 로그 유실 방지:
 - **Splunk Job** 만료 대비: 웹훅 수신 즉시 최우선 순위로 역조회(Pull) 큐에 작업을 할당하여 Splunk 서버에서 데이터가 증발하기 전에 추출합니다.
 - 메시지 큐(RabbitMQ) 영구 보장: 큐 서버 장애 시에도 데이터가 보존되도록 디스크 저장(Persistence) 설정을 강제하고, 처리 실패 시 Dead Letter Queue(DLQ)로 이관하여 관리자가 수동 재처리할 수 있게 합니다.
- 중복 적재 방지 (**Idempotency**):
 - Splunk가 네트워크 지연으로 동일한 웹훅을 재전송할 경우에 대비해, 수신된 ****sid**를 데이터베이스의 고유 식별자(Unique Key)**로 설정합니다.
 - DB 삽입(Insert) 전 `sid` 존재 여부를 검사하여, 이미 존재할 경우 무시하거나 카운트만 올리는 Upsert 처리를 수행합니다.

제3장. Jira 대체 노코드(No-Code) 설정 관리 UI

(관리자용)

이 시스템의 가장 강력한 장점은 코드 배포 없이 관리자 **UI** 화면에서 마우스 클릭과 드래그 앤 드롭만으로 새로운 고객사를 연동하고 데이터를 매핑할 수 있다는 점입니다.

3.1 신규 고객사 및 SIEM 연동 마법사 (Tenant & Source Setup)

새로운 고객사(Tenant)가 계약되었을 때, 엔지니어의 DB 수정 없이 UI에서 즉시 세팅합니다.

1. 테넌트 생성: UI에서 '고객사 추가' 버튼을 누르고 회사명, SLA 기준 시간을 입력하면 고유한 Tenant ID가 발급됩니다.
2. 연동 소스 추가: 해당 고객사 설정에서 'SIEM 연동 추가'를 클릭합니다. (Sentinel, Splunk, Logpresso 등 선택)
3. 웹훅 엔드포인트 자동 생성: 시스템이 `/api/webhook/{tenant_id}/{source_id}` 형태의 고유 URL과 인증 시크릿 키를 화면에 표시합니다. 고객사 장비에 이 URL만 등록하면 즉시 로그 수신에 준비됩니다.

3.2 Visual Data Mapper (시각적 필드 매핑 UI)

Jira에서 수동으로 커스텀 필드를 매핑하던 작업을 ****시각적 데이터 매퍼(Visual Data Mapper)****로 대체합니다.

- 매핑 UI 레이아웃:
 - 화면 좌측에는 고객사 SIEM에서 전송한 최근 로그의 ****원본 JSON 트리(Source Payload)****가 노출됩니다.
 - 화면 우측에는 우리 관제 시스템의 '표준 티켓 필드(Target Schema)' (예: 공격자 IP, 심각도, 자산명)가 나열됩니다.
- 드래그 앤 드롭 연결: 관리자가 좌측 JSON 트리의 `$.result.client_ip` 필드를 마우스로 드래그하여 우측의 Source IP 슬롯에 놓으면, 시스템 내부적으로 JSONPath 매핑 규칙이 자동 저장됩니다.
- 동적 커스텀 필드: 고객사가 특별한 필드(예: 사내_부서명) 수집을 원할 경우, DB 스키마 추가 없이 UI에서 '새 필드 추가'를 누르면 PostgreSQL의 JSONB 컬럼 내에 동적으로 속성이 추가되어 티켓 화면에 노출됩니다.

3.3 노코드 워크플로우 및 자동화 엔진 (Workflow Engine)

분석가의 티켓 처리 절차와 알림을 제어하는 규칙을 시각적으로 설계합니다.¹

- 상태 머신 빌더(State Machine Builder): UI 캔버스 상에서 티켓의 상태(New -> Analyzing -> Resolved)를 블록으로 그리고, 상태 변경 시의 조건을 설정합니다.²
 - 예: '근본 원인' 필드가 비어있으면 'Resolved' 상태로 변경 불가 (Guard 조건 설정)
 - 자동화 트리거 (Auto-Actions): "티켓 상태가 Resolved로 변경될 때" -> "고객사 A의 보안 담당자 그룹에게 이메일 템플릿 B를 발송한다"는 로직을 UI 드롭다운 형태로 구성하여 백엔드 코딩 없이 적용합니다.
-

제4장. 지능형 AI 초동 분석 코어 (AI Copilot)

티켓이 생성되어 분석가가 화면을 보기 전, AI가 1차적인 수사 보고서를 이미 완성해 둡니다.

- **RAG (검색 증강 생성) 기반 과거 이력 참조:** 새로운 IP에서 공격이 발생하면, 벡터 DB(Supabase pgvector)를 검색하여 "이 IP는 한 달 전 고객사 B에서도 탐지되었으나 사내 취약점 스캐너로 확인되어 오탐(False Positive) 처리됨"이라는 컨텍스트를 가져옵니다.
- **위협 인텔리전스(TI) 연동:** 로그 내의 IP, 도메인, 해시값을 추출해 VirusTotal이나 AbuseIPDB 등의 API를 찢러 악성 스코어를 수집합니다.
- **LLM 추론:** 수집된 원본 로그 + TI 정보 + 과거 이력을 종합하여 LLM(GPT-4o 등)에게 전달, "공격 유형, 성공 여부, 추천 조치 방안"이 포함된 요약 브리핑을 작성하게 합니다.

제5장. 관제 분석가 최적화 UI/UX (3-Pane 대시보드)

장시간 모니터링하는 분석가의 인지 부하를 줄이기 위해 React와 Tailwind CSS를 활용한 반응형 3단 분할(3-Pane) 레이아웃을 제공합니다.

1. 좌측 패널 (**목록 & 필터**): 웹소켓을 통해 새로고침 없이 티켓이 실시간으로 흘러들어옵니다. 긴급도에 따라 색상이 구분되며, 남은 처리 시간(SLA)이 카운트다운 됩니다.
2. 중앙 패널 (**분석 워크스페이스**): 선택한 티켓의 상세 정보가 표시됩니다. 최상단에는 ****AI 요약 브리핑****이 하이라이트 되며, 하단에는 정규화된 데이터 테이블과 함께 필요 시 원본 JSON을 펼쳐볼 수 있는 코드 뷰어가 제공됩니다.
3. 우측 패널 (**액션 & 플레이북**): 화면 이동 없이 즉각적인 조치를 취하는 공간입니다. '방화벽 IP 차단', '고객사 이메일 발송' 등의 원클릭 버튼이 위치하며, 고객사별 템플릿(Jinja2)이 적용된 이메일 초안을 여기서 바로 수정하고 발송할 수 있습니다.

제6장. 멀티테넌시 기반 계정 및 권한 관리 (RBAC)

B2B 관제 서비스의 특성상 타 고객사의 데이터 유출은 치명적입니다. 이를 방지하기 위해 정교한 ****RBAC(역할 기반 접근 제어)****를 UI에서 통제하도록 설계합니다.⁴

6.1 테넌트별 독립된 역할(Tenant-Scoped Roles)

전역(Global) 관리자 외에, 고객사별로 세밀한 권한 부여가 가능합니다.⁴

- **슈퍼 어드민 (자사 관제센터):** 모든 테넌트의 설정, 사용자, 데이터 접근 권한 소유.
- **L1/L2 관제 분석가:** 할당된 여러 고객사의 티켓 목록 조회 및 대응 액션 가능. 하지만 시스템 설정(매핑, 웹훅 생성) 권한은 차단.
- **고객사 보안 담당자:** 오직 ****자신의 소속 고객사(Tenant ID)****에서 발생한 티켓 목록과 대시보드만 조회 가능. 타사 데이터는 절대 볼 수 없음.

6.2 데이터베이스 레벨의 절대적 격리 (RLS)

애플리케이션(API) 코드에 버그가 있어 실수로 전체 조회를 하더라도, Supabase(PostgreSQL)의 **RLS(Row-Level Security)** 기능이 물리적으로 데이터를 차단합니다.

- 토큰 발급 시 사용자 정보에 **tenant_id**와 **role_id**를 삽입합니다.
- 모든 데이터베이스 테이블에 RLS 정책을 선언하여, 현재 사용자의 **tenant_id ==** 테이블의 **tenant_id**인 경우에만 쿼리 결과를 반환하도록 DB 엔진 자체에서 강제합니다.

6.3 계정 및 권한 관리 UI

사용자 초대, 계정 정지, 권한 할당 등 모든 기능은 **Admin Settings > Users & Roles** 화면에서 토글 버튼과 체크박스 형태로 구성되어 직관적으로 통제할 수 있습니다.

제7장. 엔드투엔드(End-to-End) 운영 프로세스 시나리오

이벤트 발생부터 고객사 알림까지, 실제 분석가가 경험하게 될 풀 프로세스 시각화입니다.

[Phase 1: 감지 및 무중단 수집 (Ingestion)]

- | 1. 이벤트 발생: 고객사 A의 SIEM(Splunk 등)에서 위협 탐지 |
 - | 2. Webhook 발송: 통합 플랫폼의 범용 API로 메타데이터(sid) 전송 |
 - | 3. 큐(Queue) 적재 & Pull: RabbitMQ 적재 후 워커가 Splunk API로 전체 로그 수집 |



[Phase 2: 동적 매핑 및 AI 초동 분석 (Processing)]

- | 1. 데이터 정규화: 관리자가 UI로 설정해둔 매핑 룰(JSONPath)이 자동 적용되어 파싱 |
 - | 2. AI 보안 분석가 개입: |
 - | - TI(VirusTotal) 평판 조회 및 과거 유사 티켓(RAG) 검색 |
 - | - LLM이 초동 분석 보고서를 작성하여 티켓 'AI Analysis' 필드 자동 기입 |



-
- | 1. 인지: UI 좌측 목록에서 붉은색(Critical) 알람 및 SLA 임박 티켓 클릭 |
 - | 2. 상태 변경: 티켓 상태를 [New] → [Analyzing(분석 중)]으로 즉시 변경 |
 - | 3. 검토: 중앙 패널에서 AI 분석 결과와 원본 로그 대조 확인 |
 - | 4. 조치: 우측 패널에서 'IP 방화벽 차단' 또는 '계정 잠금' 액션 실행 |
-



-
- | 1. 종결 처리: 근본 원인(Root_Cause) 기입 후 상태를로 변경 |
 - | 2. 리포트 렌더링: 시스템이 티켓 데이터를 고객사 A의 HTML 템플릿에 자동 삽입 |
 - | 3. 메일 발송: 설정된 담당자 메일 주소로 분석 내역 및 권고 사항 자동 발송 |
 - | 4. 지식 자산화: 해당 티켓의 처리 결과가 벡터 DB에 동기화되어 향후 AI의 학습 활용 |
-

제8장. AI 페어 프로그래밍(Vibe Coding) 공동 개발 실천 계획

개발 지식이 깊지 않더라도 저(AI)와 함께 바이브 코딩 (Vibe Coding) 방식을 통해 이 엔터프라이즈급 플랫폼을 체계적으로 구축할 수 있습니다. 우리는 다음과 같은 순서로 페어 프로그래밍을 진행할 것입니다.⁶

단계별 개발 로드맵 (Action Plan)

1. **Phase 1: 기획 및 데이터베이스 뼈대 세우기 (Supabase)**
 - 당신의 역할: 저에게 "테넌트(고객사) 테이블과, JSONB를 지원하는 티켓 테이블, 그리고 철저하게 격리되는 RLS(보안) 정책을 생성하는 SQL 문을 짜줘"라고 요청합니다.
 - 나의 역할: 그대로 Supabase의 SQL 편집기에 복사하여 실행할 수 있는 완벽한 데이터베이스 생성 스크립트와 보안 정책을 작성해 드립니다.
2. **Phase 2: 고성능 로그 수집기 개발 (FastAPI + RabbitMQ)**
 - 당신의 역할: Cursor IDE를 열고 "FastAPI를 사용해서 SIEM 웹훅을 받아 RabbitMQ에 넣는 수집기를 짜줘. 그리고 Splunk의 역조회(Pull) 로직을 Celery 워커로 만들어줘"라고

명령합니다.

- 나의 역할: 오류 처리와 예외 상황(DLQ 등)을 모두 포함한 백엔드 파이썬 코드를 제공합니다.

3. Phase 3: 관제 화면 및 설정 UI 구축 (Next.js + Lovable/v0)

- 당신의 역할: Lovable이나 v0.dev 같은 AI UI 생성기에 "Jira처럼 좌측에는 메뉴가 있고, 가운데에 3단 분할(3-Pane) 관제 화면이 있는 다크 모드 대시보드를 만들어줘. 그리고 관리자가 JSON 필드를 드래그 앤 드롭으로 매핑하는 설정 화면도 필요해"라고 프롬프트를 입력합니다.⁷
- 나의 역할: 생성된 React 컴포넌트를 제공하며, 이를 Phase 2에서 만든 백엔드 API와 매끄럽게 연결(데이터 바인딩)하는 코드를 작성해 드립니다.

4. Phase 4: AI 분석 및 워크플로우 통합

- 당신의 역할: "수집된 티켓 JSON 데이터를 OpenAI API에 보내 분석하는 스크립트를 작성하고, 상태가 Resolved로 바뀌면 고객 메일을 발송하도록 연결해줘"라고 요청합니다.
- 나의 역할: 프롬프트 엔지니어링이 적용된 AI 분석 호출 로직과, 상태 머신 기반의 메일 발송 파이썬 스크립트를 완성해 드립니다.

실행 원칙: 우리는 한 번에 모든 것을 만들지 않습니다. 기능 하나(예: 웹훅 수신기)를 만들어 테스트하고 완벽히 작동하면, 다음 기능(UI 연동)으로 넘어가는 '수직적 쪼개기(Slice Vertically)' 방식으로 진행하여 복잡도를 낮추고 성공률을 100%로 끌어올릴 것입니다.⁶

참고 자료

1. Branches - Logical Step and Parallel execution - Knowledge Center - CM.com, 2월 19, 2026에 액세스, <https://knowledgecenter.cm.com/knowledge-center/halo/introduction-into-tools/steps-branches-and-outputs/branches-logical-step-and-parallel-execution>
2. Building Workflows, Part 1 — Core concepts and the Workflow ..., 2월 13, 2026에 액세스, <https://incident.io/blog/building-workflows-part-1>
3. How we built a highly scalable distributed state machine | by Bernd Rücker - berndruecker, 2월 13, 2026에 액세스, <https://blog.bernd-ruecker.com/how-we-built-a-highly-scalable-distributed-state-machine-f2595e3c0422>
4. How to design an RBAC model for multi-tenant SaaS - WorkOS, 2월 13, 2026에 액세스, <https://workos.com/blog/how-to-design-multi-tenant-rbac-saas>
5. Learn more about the RBAC permissions specifically about role permissions by component and the default Palo Alto Networks roles. - Administrator Guide - Cortex XSIAM, 2월 13, 2026에 액세스, <https://docs-cortex.paloaltonetworks.com/r/Cortex-XSIAM/Cortex-XSIAM-Documentation/RBAC-permissions>
6. A Structured Workflow for "Vibe Coding" Full-Stack Apps - DEV Community, 2월 19, 2026에 액세스, <https://dev.to/wasp/a-structured-workflow-for-vibe-coding-full-stack-apps-352l>
7. Cursor workflows for building SaaS products in 2025 | N's Blog - Namanyay Goel,

2월 13, 2026에 액세스, <https://nmn.gl/blog/building-with-ai>